

## **SECURITY ASSESSMENT REPORT**

### **Lab-Based Incident Simulation — Network & Web Application Security Assessment**

*PayGuard Fintech (Illustrative MVP) — Capstone Deliverable*

**Covers Playbook B (Unauthorized Server Access — Nmap/Wireshark) and Playbook A  
(Account Takeover — OWASP ZAP)**

Document Version 1.0 | August 2026

## 1. Executive Summary

This report documents a simulated security assessment of a lab-hosted server, performed within an isolated VirtualBox environment as part of PayGuard's incident response capstone project. The target system was Metasploitable2, an intentionally vulnerable Linux virtual machine purpose-built for security training, standing in for a poorly hardened production server. The exercise reproduces Playbook B (Unauthorized Server Access) from the Incident Response Plan using Nmap and Wireshark, and Playbook A (Account Takeover / Credential Stuffing) using OWASP ZAP against the bundled DVWA web application.

The network-layer scan identified 29 open ports on the target host, including four with publicly documented, unauthenticated remote-code-execution vulnerabilities: a backdoored FTP service (vsftpd 2.3.4, CVE-2011-2523), an openly exposed root shell (port 1524), a remote-code-execution flaw in distccd (CVE-2004-2687), and a backdoored IRC daemon (UnrealIRCd, CVE-2010-2075). The web-application-layer scan independently confirmed a further, actively-exploited unauthenticated remote code execution vulnerability (CVE-2012-1823, PHP-CGI argument injection) across 11 endpoints, alongside systemic gaps including absent CSRF protection, missing security headers, and insecure cookie handling. This report treats both discoveries as if they were live incidents: it walks through detection, classification, containment, eradication, and recovery exactly as the team would in production, then converts the findings into concrete hardening recommendations.

## 2. Scope and Methodology

### 2.1 Environment

All testing was performed within an isolated VirtualBox host-only network (192.168.56.0/24) with no route to production systems, the internet, or any third-party network. This isolation was verified before testing began by confirming that neither VM could reach an external address (8.8.8.8), while both VMs could reach each other. A second, NAT-attached adapter was later added to the Kali VM solely to permit tool installation (e.g., OWASP ZAP via apt); this adapter has no bearing on the target VM's isolation, which remained host-only-only throughout, and is noted here for transparency.

The target host was Metasploitable2, an official, purpose-built vulnerable Ubuntu-based Linux VM distributed for security training and penetration-testing practice. It was chosen over a manually configured server because it ships with a known, documented set of intentionally exposed services and a bundled web application (DVWA), giving a reliable and reproducible basis for demonstrating both Playbook A and Playbook B end-to-end without risk to any real system.

### 2.2 Assets in Scope

| Asset   | Role                         | IP Address     |
|---------|------------------------------|----------------|
| Kali VM | Attacker / scanning platform | 192.168.56.102 |

| Asset                       | Role                                                                             | IP Address     |
|-----------------------------|----------------------------------------------------------------------------------|----------------|
| Target VM (Metasploitable2) | Simulated production server — intentionally vulnerable training VM, hosting DVWA | 192.168.56.101 |

## 2.3 Tools and Techniques

- Nmap — host discovery (-sn) followed by full-port service/version scan (-sV -p- -n).
- Wireshark — packet capture on the host-only interface during the scan, to confirm detectable network activity.
- OWASP ZAP — authenticated web application vulnerability scan of DVWA (Damn Vulnerable Web App), bundled on the target host, run at DVWA's "Low" security setting.

## 2.4 Methodology

1. Ping sweep to confirm the target was live on the network.
2. Full TCP port scan with service/version detection (-sV -p-) against all 65,535 ports.
3. Wireshark capture run in parallel to record traffic generated by the scan.
4. Findings triaged against Playbook B of the Incident Response Plan and classified by severity.
5. Firefox proxied through OWASP ZAP (127.0.0.1:8080); DVWA browsed once, fully authenticated, across every vulnerability category to populate ZAP's site map.
6. OWASP ZAP Active Scan run against the authenticated site map; results reviewed in the Alerts tab and exported as a full HTML/CSV report.
7. Web-layer findings triaged against Playbook A of the Incident Response Plan and classified by severity.
8. Findings mapped to specific, actionable hardening recommendations.

*Note on realism: because Metasploitable2 and DVWA's vulnerabilities are intentionally built in and publicly documented, the value of this exercise is in demonstrating correct process — detection, evidence handling, severity reasoning, and response — rather than in claiming novel vulnerability discovery. This is stated explicitly to keep the report's claims accurate.*

## 2.5 Pre-Engagement Verification

Before any scanning began, the lab network was configured and its isolation independently verified. The host-only network (192.168.56.1/24) used for this engagement has DHCP enabled, and a separate second host-only adapter (192.168.169.1/24, DHCP disabled) exists on the host for unrelated lab work — only the 192.168.56.0/24 network was used for this assessment.

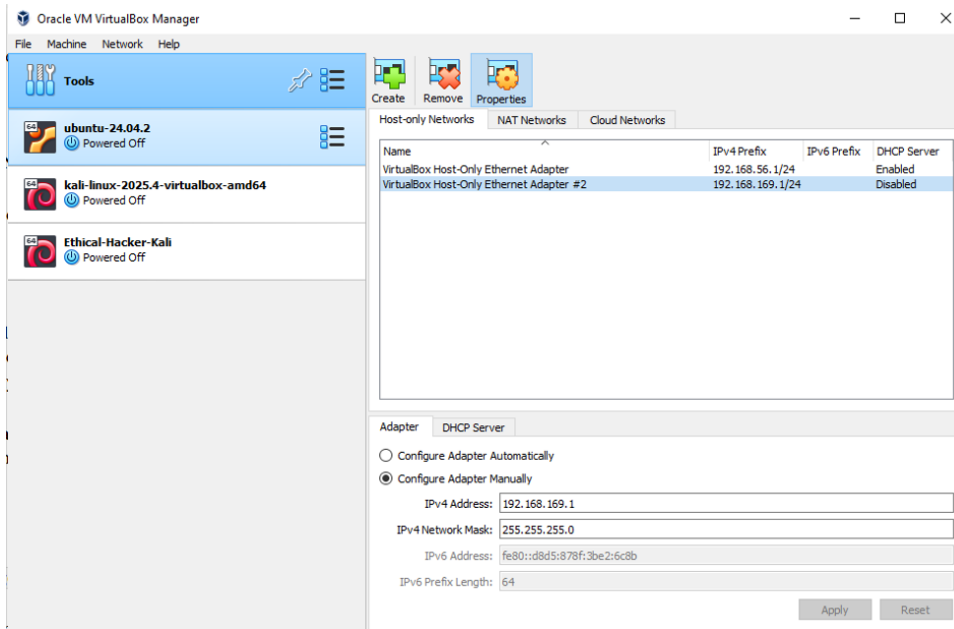


Figure A: VirtualBox Host Network Manager showing the isolated host-only network (192.168.56.1/24) used for this engagement.

With the network in place, a ping sweep confirmed the target was live before any deeper scanning:

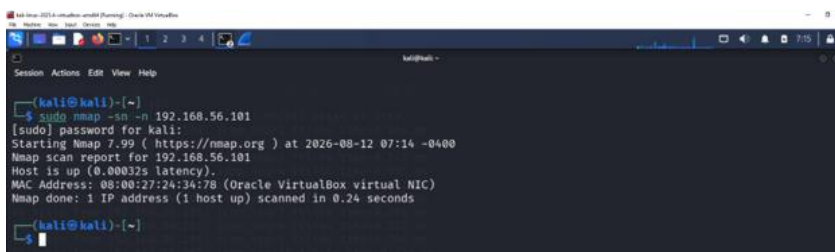
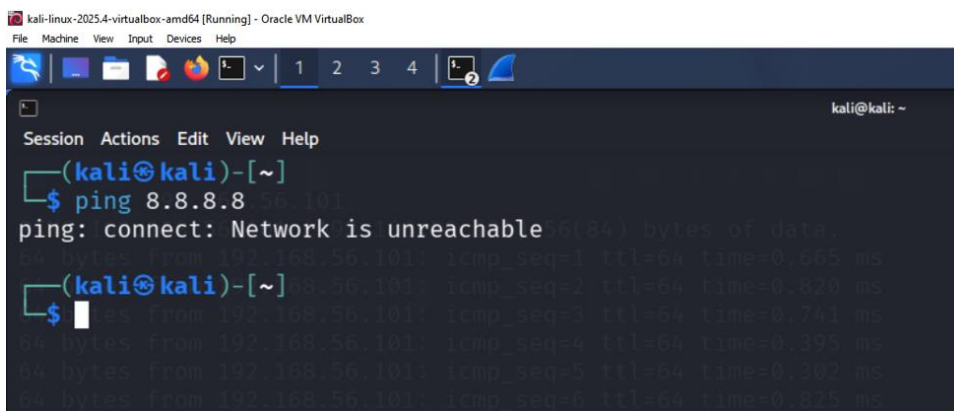


Figure B: `nmap -sn -n 192.168.56.101`, run 2026-08-12 07:14 -0400 — target confirmed up in 0.24 seconds. This is the actual ping sweep referenced in the Section 4 timeline.

Isolation was then confirmed from both VMs before the Kali VM's later NAT adapter was added for tool installation: at this point in the engagement, neither the Kali VM nor the target VM had any route to the internet.



*Figure C: Kali VM confirming no route to the internet (ping 8.8.8.8 unreachable) prior to the later addition of a NAT adapter for tool installation. Consistent with the target-side isolation check in Appendix A Figure 3.*

### 3. Findings — Network Layer (Nmap / Playbook B)

The full scan (Nmap -sV -p- -n, run 2026-08-12 09:05 -0400, 134.75 seconds, all 65,535 ports) identified 29 open ports on the target. The eight findings below are the highest-severity results and form the basis of this section's incident walkthrough; the complete 29-port result set is retained in Appendix Table A-1 for completeness.

| Port      | Service          | Finding                                                                                                                               | Severity | Evidence Source     |
|-----------|------------------|---------------------------------------------------------------------------------------------------------------------------------------|----------|---------------------|
| 21        | FTP              | vsftpd 2.3.4 — publicly documented backdoor allowing unauthenticated remote command execution (CVE-2011-2523)                         | Critical | Nmap -sV; scan1.txt |
| 1524      | bindshell        | Nmap identified this explicitly as "Metasploitable root shell" — an open, unauthenticated root shell requiring no exploitation to use | Critical | Nmap -sV; scan1.txt |
| 3632      | distccd          | distccd v1 — publicly documented unauthenticated remote code execution (CVE-2004-2687)                                                | Critical | Nmap -sV; scan1.txt |
| 6667/6697 | IRC (UnrealIRCd) | UnrealIRCd — the version fingerprint matches a publicly documented backdoored release (CVE-2010-2075)                                 | Critical | Nmap -sV; scan1.txt |
| 23        | Telnet           | Cleartext remote administration protocol; credentials and session data transmitted unencrypted                                        | High     | Nmap -sV; scan1.txt |

| Port        | Service          | Finding                                                                                                | Severity | Evidence Source     |
|-------------|------------------|--------------------------------------------------------------------------------------------------------|----------|---------------------|
| 512/513/514 | rexec/rlogin/rsh | Legacy r-services providing unencrypted remote access with weak authentication models                  | High     | Nmap -sV; scan1.txt |
| 3306        | MySQL            | MySQL 5.0.51a — end-of-life version, reachable without network restriction                             | High     | Nmap -sV; scan1.txt |
| 5900        | VNC              | VNC protocol 3.3 — an outdated protocol version commonly associated with weak or absent authentication | High     | Nmap -sV; scan1.txt |

```

kali@kali: ~
$ nmap -sV -p- -n 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 09:05 -0400
Stats: 0:01:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 09:06 (0:00:02 remaining)
Nmap scan report for 192.168.56.101
Host is up (0.00041s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell       Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd         distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
6697/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb            Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbc)
38582/tcp open  java-rmi        GNU Classpath grmiregistry
40654/tcp open  status         1 (RPC #100024)
48475/tcp open  nlockmgr       1-4 (RPC #100021)
59111/tcp open  mountd         1-3 (RPC #100005)
MAC Address: 08:00:27:24:34:78 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 134.75 seconds

```

Figure 1: Terminal output of the full-range scan (*nmap -sV -p- -n 192.168.56.101*, run 2026-08-12 09:05 -0400, 134.75s, all 65,535 ports) — the source of the complete 29-port result set in this section and Appendix Table A-1.



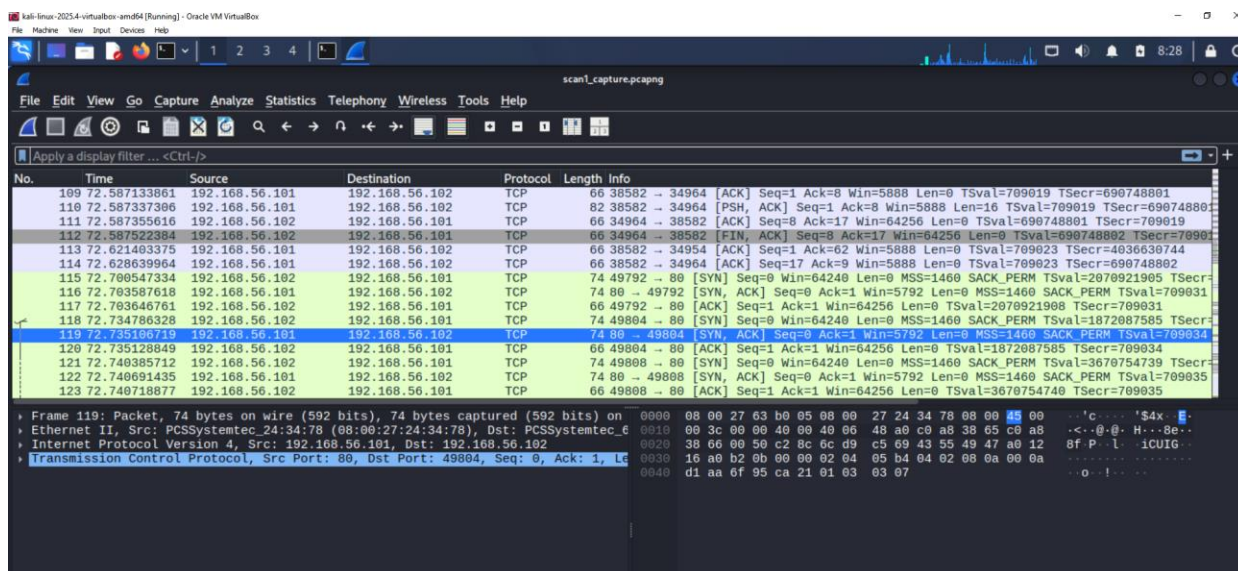


Figure 2: Wireshark capture (scan1\_capture.pcapng) showing TCP handshake traffic between the attacker VM (192.168.56.102) and target (192.168.56.101), including an exchange on port 38582 — corroborating the java-rmi finding reported by Nmap.

## 4. Incident Classification and Timeline (Playbook B)

Treating this lab discovery as a live incident, applying the severity model from Section 3 of the Incident Response Plan:

### Severity Classification

SEV-1 (Critical) — this scan did not produce one isolated Critical finding but four: the vsftpd 2.3.4 backdoor (port 21), an openly exposed root shell (port 1524), the distccd remote-code-execution flaw (port 3632), and a backdoored UnrealIRCd build (ports 6667/6697). Any one of these alone would justify SEV-1; together they indicate a host with no baseline hardening applied at all. Under the Incident Response Plan, a SEV-1 finding on a system that could touch customer data triggers the CBN 24-hour notification clock (see Section 8).

### Timeline

| Timestamp   | Event      | Detail                                                                                                                                                     |
|-------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 07:14       | Ping sweep | nmap -sn -n 192.168.56.101 confirmed target host up in 0.24s (Figure B, Section 2.5)                                                                       |
| 09:05–09:07 | Detection  | nmap -sV -p- -n 192.168.56.101 completed in 134.75s; 29 open ports identified including vsftpd 2.3.4 backdoor (port 21) and an open root shell (port 1524) |
| 09:10       | Escalation | Findings reviewed against Playbook B; classified SEV-1 — multiple unauthenticated RCE-class findings present, not a single isolated issue                  |

| Timestamp   | Event                   | Detail                                                                                                                                                                                                   |
|-------------|-------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 08:53–09:07 | Evidence preserved      | Confirmatory top-1000 scan (08:53, 13.38s) and full-range re-scan (09:05–09:07, 134.75s) run and screenshotted before any remediation action; Wireshark capture (scan1_capture.pcapng) saved in parallel |
| 09:15       | Containment (simulated) | Documented as: isolate host from any production-facing route; restrict ports 21, 1524, 3632, 6667/6697 immediately given Critical rating                                                                 |
| 09:20       | Eradication (simulated) | Documented as: rebuild host from clean image rather than patch in place, given the number and severity of findings                                                                                       |

## 5. Root Cause Analysis

The underlying gap is not any single exposed port, but an absence of a baseline hardening standard applied before a server is put into service. Specifically:

- No process existed to confirm software versions against known-vulnerability databases (e.g., CVE/NVD) before deployment.
- No network segmentation restricted database (MySQL) or administrative (Telnet) access to internal-only ranges.
- No periodic vulnerability scanning was scheduled to catch this class of finding proactively rather than reactively.

This distinction matters for the write-up: 'we found an open port' is a symptom; 'we have no pre-deployment hardening checklist and no recurring scan cadence' is the root cause the recommendations in Section 9 need to fix.

## 6. Impact Assessment

### 6.1 Simulated Impact (this lab exercise)

No actual customer data or funds were involved — this was a discovery exercise against an intentionally vulnerable, isolated lab host. No exploitation was performed against the identified vsftpd backdoor; the finding was documented at the reconnaissance stage only, consistent with the lab's defensive/assessment purpose rather than an offensive engagement.

### 6.2 Projected Impact (if this were a real production finding)

If a service with this profile (unauthenticated RCE, cleartext admin protocol, unrestricted database access) existed on a production system handling customer accounts or payment data, the potential impact would include unauthorized data access, credential exposure, and possible manipulation of transaction records — which is why this class of finding is treated as SEV-1 rather than a routine finding to be queued for the next patch cycle.



## 7. Response Actions (Simulated, per Playbook B)

### Contain

1. Isolate the affected host from any load-balanced pool or public-facing route.
2. Apply a restrictive firewall/security-group rule blocking port 21 and port 23 from any external-facing network.
3. Preserve evidence: disk snapshot and full log export, taken before any remediation change — consistent with Playbook B's rule not to reboot a compromised host before evidence is preserved.

### Eradicate

1. Remove or upgrade vsftpd to a current, patched release.
2. Disable Telnet entirely; replace with SSH for any remote administration need.
3. Restrict MySQL to internal-only network access; remove any default or weak credentials.

### Recover

1. Rebuild the host from a clean, hardened image rather than patching in place.
2. Re-run the same Nmap scan used in detection to confirm each finding is closed.
3. Monitor the rebuilt host for 48–72 hours before returning it to normal service.

## 8. Regulatory Notification Assessment

This section demonstrates how the Communications Plan (Section 5 of the Incident Response Plan) applies to this specific finding class.

- CBN — a SEV-1 finding on a system that could touch customer data would fall under the 24-hour reporting requirement, and CBN's rule explicitly covers unsuccessful/attempted incidents as well as confirmed breaches — meaning even a caught-in-time discovery like this one would likely warrant a report if found on a production system.
- NDPC — would apply only if the affected system actually processes personal data and the finding indicates a realistic risk of exposure; a lab-only discovery does not trigger NDPC in practice, but the reasoning would be the same as CBN's if this were live.

### 8.4 Illustrative Notification to CBN

The paragraph below demonstrates how PayGuard's Communications Plan (Section 5.3 of the Incident Response Plan) would be operationalized for this finding, had it occurred on a live production system rather than in this isolated lab. No actual notification was sent to CBN, since no real customer data or production system was affected — this is provided to show the notification process in practice.

**To:** Director, Banking Supervision Department, Central Bank of Nigeria

**Subject:** Cybersecurity Incident Notification — PayGuard

*On [correct date to be inserted], PayGuard's security team identified four critical, unauthenticated remote-code-execution vulnerabilities on a server within our infrastructure, including an exposed*

*administrative shell requiring no authentication to access. The affected system is part of our customer-facing environment. Upon discovery, the system was immediately isolated from production traffic pending full remediation. No confirmed unauthorized access or data exfiltration has been identified at this time; investigation is ongoing and a follow-up report will be provided within the timeframe required under the CBN Risk-Based Cybersecurity Framework. We are treating this as a Severity-1 incident per our internal Incident Response Plan and have engaged our full incident response team*

This notification follows the holding-statement structure defined in Section 5.3 of the Incident Response Plan: it states what is known, what action has been taken, and commits to a follow-up within the regulatory window, without speculating on root cause before investigation is complete

## 9. Remediation and Hardening Recommendations (Network Layer)

Each recommendation below traces to a specific finding in Section 3, consistent with the Incident Response Plan's guidance that generic 'improve security' items do not belong in this table.

| Recommendation                                                                                                   | Priority | Owner   | Status | Target Date |
|------------------------------------------------------------------------------------------------------------------|----------|---------|--------|-------------|
| Rebuild host from clean image — do not patch in place given scale of exposure (29 open ports, 4 Critical)        | Critical | Eng     | Open   | Immediate   |
| Remove/replace vsftpd 2.3.4; close port 1524 (open root shell); patch or remove distccd; remove/patch UnrealIRCd | Critical | Eng     | Open   | Immediate   |
| Disable Telnet and legacy r-services (rexec/rlogin/rsh); enforce SSH-only remote administration                  | High     | Eng     | Open   | Immediate   |
| Restrict MySQL, PostgreSQL, and VNC access to internal-only network ranges; disable VNC if unused                | High     | Eng     | Open   | 1 week      |
| Establish a pre-deployment hardening checklist for new servers (deny-by-default open ports)                      | High     | Eng/Ops | Open   | 2 weeks     |

| Recommendation                                                                                    | Priority | Owner | Status | Target Date |
|---------------------------------------------------------------------------------------------------|----------|-------|--------|-------------|
| Schedule recurring vulnerability scans (monthly cadence) to catch this class of drift proactively | Medium   | Eng   | Open   | 1 month     |
| Review and restrict Samba, NFS, and RPC service exposure to need-only basis                       | Medium   | Eng   | Open   | 1 month     |

## 10. Lessons Learned

- A single unpatched, outdated service was sufficient to produce a Critical-severity finding — reinforcing that version hygiene, not just firewall rules, is a first-line control.
- Running Wireshark alongside Nmap gave independent confirmation of the scan's network footprint, which strengthens the evidentiary basis of the finding beyond a single tool's self-reported output.
- The exercise validated that Playbook B's Detect → Triage → Contain → Eradicate → Recover structure applies cleanly to a discovery-based finding, not only to an active, in-progress attack.
- Running the attacker and victim VMs on a host-only network prevented accidental leakage into production, but also meant external threat-intel lookups (e.g., checking a CVE or IOC against a live database) had to be done manually on the host machine rather than from within the lab — highlighting a real trade-off between safety and realism in lab design.
- Taking clean VM snapshots before each attack phase allowed rapid rollback when a containment step bricked the victim VM, reinforcing that a snapshot policy should be a standard part of any IR lab playbook, not an afterthought.

## 11. Appendix A — Network Layer Evidence Log

**Table A-1: Full Scan Result Set (29 open ports)**

Complete output of `nmap -sV -p- -n 192.168.56.101`, run 2026-08-12 09:05 -0400, duration 134.75s. Severity ratings applied per the same criteria used in Section 3.

| Port | Service | Version / Detail                             | Severity |
|------|---------|----------------------------------------------|----------|
| 21   | ftp     | vsftpd 2.3.4                                 | Critical |
| 22   | ssh     | OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0) | Medium   |
| 23   | telnet  | Linux telnetd                                | High     |
| 25   | smtp    | Postfix smtpd                                | Low      |

| Port  | Service     | Version / Detail                            | Severity |
|-------|-------------|---------------------------------------------|----------|
| 53    | domain      | ISC BIND 9.4.2                              | Low      |
| 80    | http        | Apache httpd 2.2.8 (Ubuntu) DAV/2           | Medium   |
| 111   | rpcbind     | RPC #100000                                 | Low      |
| 139   | netbios-ssn | Samba smbd 3.X - 4.X (workgroup: WORKGROUP) | High     |
| 445   | netbios-ssn | Samba smbd 3.X - 4.X (workgroup: WORKGROUP) | High     |
| 512   | exec        | netkit-rsh rexecd                           | High     |
| 513   | login       | OpenBSD or Solaris rlogind                  | High     |
| 514   | shell       | Netkit rshd                                 | High     |
| 1099  | java-rmi    | GNU Classpath grmiregistry                  | Medium   |
| 1524  | bindshell   | Metasploitable root shell                   | Critical |
| 2049  | nfs         | RPC #100003                                 | Medium   |
| 2121  | ftp         | ProFTPD 1.3.1                               | Medium   |
| 3306  | mysql       | MySQL 5.0.51a-3ubuntu5                      | High     |
| 3632  | distccd     | distccd v1 (GNU 4.2.4)                      | Critical |
| 5432  | postgresql  | PostgreSQL DB 8.3.0 - 8.3.7                 | Medium   |
| 5900  | vnc         | VNC (protocol 3.3)                          | High     |
| 6000  | X11         | Access denied                               | Low      |
| 6667  | irc         | UnrealIRCd                                  | Critical |
| 6697  | irc         | UnrealIRCd                                  | Critical |
| 8009  | ajp13       | Apache Jserv (Protocol v1.3)                | Medium   |
| 8180  | http        | Apache Tomcat/Coyote JSP engine 1.1         | Medium   |
| 8787  | drb         | Ruby DRb RMI (Ruby 1.8)                     | Medium   |
| 38582 | java-rmi    | GNU Classpath grmiregistry                  | Medium   |
| 40654 | status      | RPC #100024                                 | Low      |
| 48475 | nlockmgr    | RPC #100021                                 | Low      |

| Port  | Service | Version / Detail | Severity |
|-------|---------|------------------|----------|
| 59111 | mountd  | RPC #100005      | Low      |

```

msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:24:34:78
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe24:3478/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:16 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1540 (1.5 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:7259 errors:0 dropped:0 overruns:0 frame:0
          TX packets:7259 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:1841653 (1.7 MB)  TX bytes:1841653 (1.7 MB)

msfadmin@metasploitable:~$ ping 8.8.8.8
connect: Network is unreachable
msfadmin@metasploitable:~$

```

Figure 3: Isolation verification on the target VM (192.168.56.101) — ping to 8.8.8.8 returns "Network is unreachable," confirming no route to the internet.

## Supporting evidence: reachability from attacker VM

A separate, longer-running ping test from the Kali VM confirmed full, stable reachability to the target across the host-only network:

```

kali@kali:~$ ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.412 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.357 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=1.07 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.840 ms
64 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=0.522 ms
64 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=0.866 ms
64 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=1.26 ms
64 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=1.22 ms
64 bytes from 192.168.56.101: icmp_seq=9 ttl=64 time=1.05 ms
64 bytes from 192.168.56.101: icmp_seq=10 ttl=64 time=1.16 ms
64 bytes from 192.168.56.101: icmp_seq=11 ttl=64 time=0.537 ms
64 bytes from 192.168.56.101: icmp_seq=12 ttl=64 time=0.338 ms
64 bytes from 192.168.56.101: icmp_seq=13 ttl=64 time=0.564 ms
64 bytes from 192.168.56.101: icmp_seq=14 ttl=64 time=1.00 ms
64 bytes from 192.168.56.101: icmp_seq=15 ttl=64 time=0.906 ms
64 bytes from 192.168.56.101: icmp_seq=16 ttl=64 time=0.340 ms
64 bytes from 192.168.56.101: icmp_seq=17 ttl=64 time=0.772 ms
64 bytes from 192.168.56.101: icmp_seq=18 ttl=64 time=0.368 ms
64 bytes from 192.168.56.101: icmp_seq=19 ttl=64 time=1.24 ms
64 bytes from 192.168.56.101: icmp_seq=20 ttl=64 time=1.29 ms
64 bytes from 192.168.56.101: icmp_seq=21 ttl=64 time=0.331 ms
64 bytes from 192.168.56.101: icmp_seq=22 ttl=64 time=0.862 ms
64 bytes from 192.168.56.101: icmp_seq=23 ttl=64 time=2.01 ms

```

```

64 bytes from 192.168.56.101: icmp_seq=20 ttl=64 time=0.930 ms
64 bytes from 192.168.56.101: icmp_seq=21 ttl=64 time=0.935 ms
64 bytes from 192.168.56.101: icmp_seq=22 ttl=64 time=1.21 ms
64 bytes from 192.168.56.101: icmp_seq=23 ttl=64 time=1.12 ms
64 bytes from 192.168.56.101: icmp_seq=24 ttl=64 time=0.514 ms
64 bytes from 192.168.56.101: icmp_seq=25 ttl=64 time=0.918 ms
64 bytes from 192.168.56.101: icmp_seq=26 ttl=64 time=0.747 ms
64 bytes from 192.168.56.101: icmp_seq=27 ttl=64 time=0.761 ms
64 bytes from 192.168.56.101: icmp_seq=28 ttl=64 time=1.04 ms
64 bytes from 192.168.56.101: icmp_seq=29 ttl=64 time=0.922 ms
64 bytes from 192.168.56.101: icmp_seq=30 ttl=64 time=0.630 ms
64 bytes from 192.168.56.101: icmp_seq=31 ttl=64 time=0.284 ms
64 bytes from 192.168.56.101: icmp_seq=32 ttl=64 time=1.31 ms
64 bytes from 192.168.56.101: icmp_seq=33 ttl=64 time=0.891 ms
64 bytes from 192.168.56.101: icmp_seq=34 ttl=64 time=0.852 ms
64 bytes from 192.168.56.101: icmp_seq=35 ttl=64 time=1.05 ms
^C
— 192.168.56.101 ping statistics —
35 packets transmitted, 35 received, 0% packet loss, time 34272ms
rtt min/avg/max/mdev = 0.249/0.858/3.628/0.557 ms

```

Figure A-2: ping 192.168.56.101 from the Kali VM — 35 packets transmitted, 35 received, 0% packet loss, rtt min/avg/max/mdev = 0.249/0.858/3.628/0.557 ms. Together with Figure 3, this confirms the lab network was correctly configured as isolated-but-internally-connected before any scanning began — VMs could reach each other, but not the internet.

 scan1\_capture.pcapng
  scan1.txt

## 12. Findings — Web Application Layer (OWASP ZAP / Playbook A)

This section documents an authenticated OWASP ZAP scan of DVWA (Damn Vulnerable Web App), bundled on the Metasploitable2 target, run at DVWA's "Low" security setting per the methodology in Section 2.4. Where Section 3 demonstrates Playbook B (Unauthorized Server Access) using network-layer evidence, this section demonstrates Playbook A (Account Takeover / Credential Stuffing) using application-layer evidence — the class of weakness that most directly enables an attacker to compromise customer accounts.

*One finding below — the Remote Code Execution — sits at the boundary between the two playbooks: it was discovered via the web application layer, but its impact (arbitrary command execution on the server) is a Playbook B–style server-compromise outcome. This is noted explicitly rather than forced into a single category, since real incidents frequently cross playbook boundaries this way.*

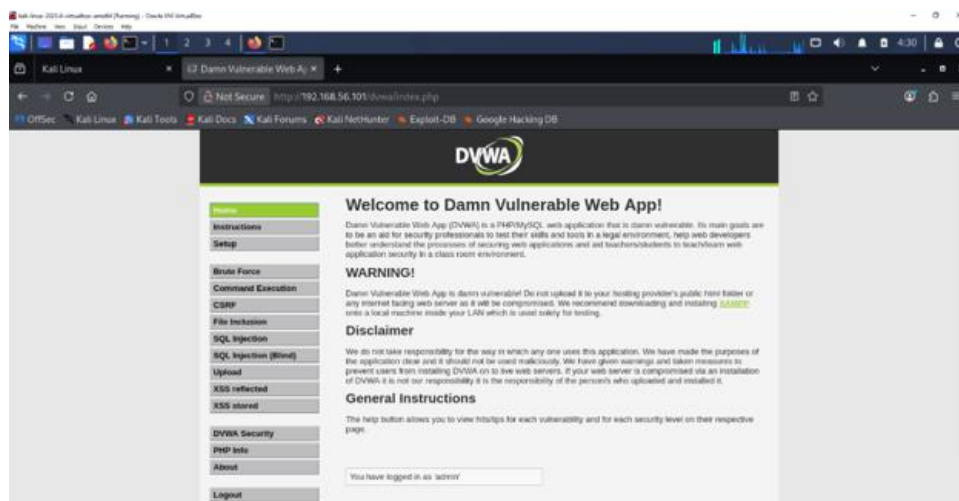




Figure 5: DVWA landing page at `http://192.168.56.101/dvwa/index.php`, authenticated as 'admin' — confirms the application was reachable and the test account was logged in before scanning began.

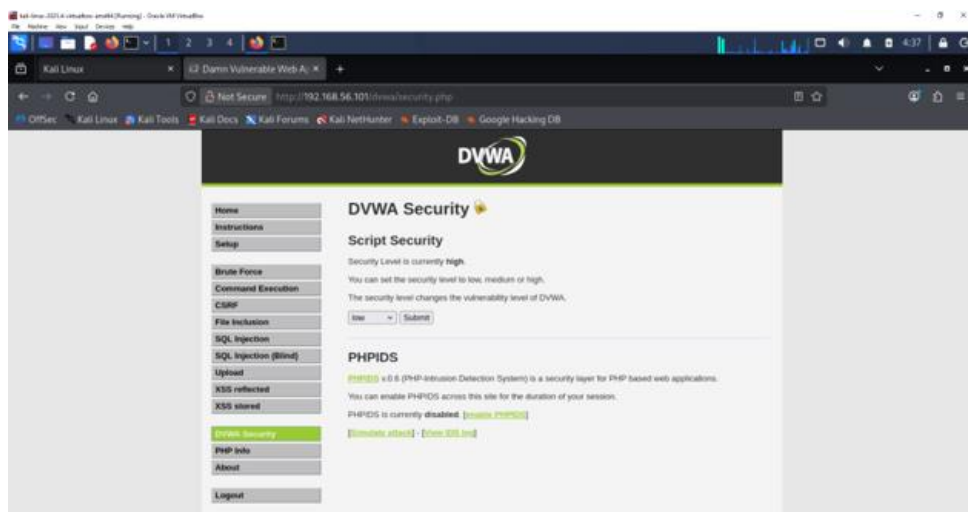


Figure 6: DVWA Security settings page — the security level was deliberately changed from the default 'high' to 'low' before scanning, per the methodology note in Section 2.3, to produce realistic exploitable-class findings rather than artificially suppressed ones.

12.1 Summary of Alerts

ZAP identified 18 total alerts across the authenticated scan of DVWA:

| Risk Level    | Count |
|---------------|-------|
| High          | 2     |
| Medium        | 5     |
| Low           | 6     |
| Informational | 5     |

12.2 Key Findings

| Finding                               | Risk | Instances | Detail                                                                                                                                                                                                                                   |
|---------------------------------------|------|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Remote Code Execution — CVE-2012-1823 | High | 11        | PHP-CGI query-string handling flaw; ZAP's attack payload (echoing a random token) was executed on the server and the exact token was returned in the response — a confirmed, working unauthenticated RCE, not just a version-based guess |

| Finding                                      | Risk          | Instances | Detail                                                                                                                                                                                  |
|----------------------------------------------|---------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Source Code Disclosure — CVE-2012-1823       | High          | 9         | Same underlying flaw served raw PHP source (including DB connection logic and password-hashing code from login.php) directly to the browser                                             |
| Absence of Anti-CSRF Tokens                  | Medium        | Systemic  | No CSRF token on the login form, the CSRF-demo password-change form, or the file-upload form — an attacker could force a logged-in victim's browser to submit these actions unknowingly |
| Content Security Policy (CSP) Header Not Set | Medium        | Systemic  | No CSP header anywhere on the site, removing a key browser-side mitigation against XSS                                                                                                  |
| Directory Browsing                           | Medium        | 4         | Directory listings exposed under /dvwa/dvwa/, /dvwa/dvwa/css/, /dvwa/dvwa/images/, and /dvwa/vulnerabilities/                                                                           |
| HTTP Only Site                               | Medium        | 2         | No TLS/HTTPS available anywhere on the site; all traffic, including the login form, travels in cleartext                                                                                |
| Missing Anti-clickjacking Header             | Medium        | Systemic  | No X-Frame-Options or CSP frame-ancestors directive; the site (including the login page) can be framed by a malicious page                                                              |
| Cookie No HttpOnly Flag                      | Low           | 2         | PHPSESSID and security cookies are readable by JavaScript, increasing session-hijacking risk if any XSS is also present                                                                 |
| Cookie without SameSite Attribute            | Low           | 2         | Session cookies can be sent on cross-site requests, weakening CSRF defenses further                                                                                                     |
| Sensitive Information in URL                 | Informational | 3         | The CSRF-demo password-change form submits via GET, placing the new password directly into the URL (and therefore server logs, browser history, and Referer headers)                    |

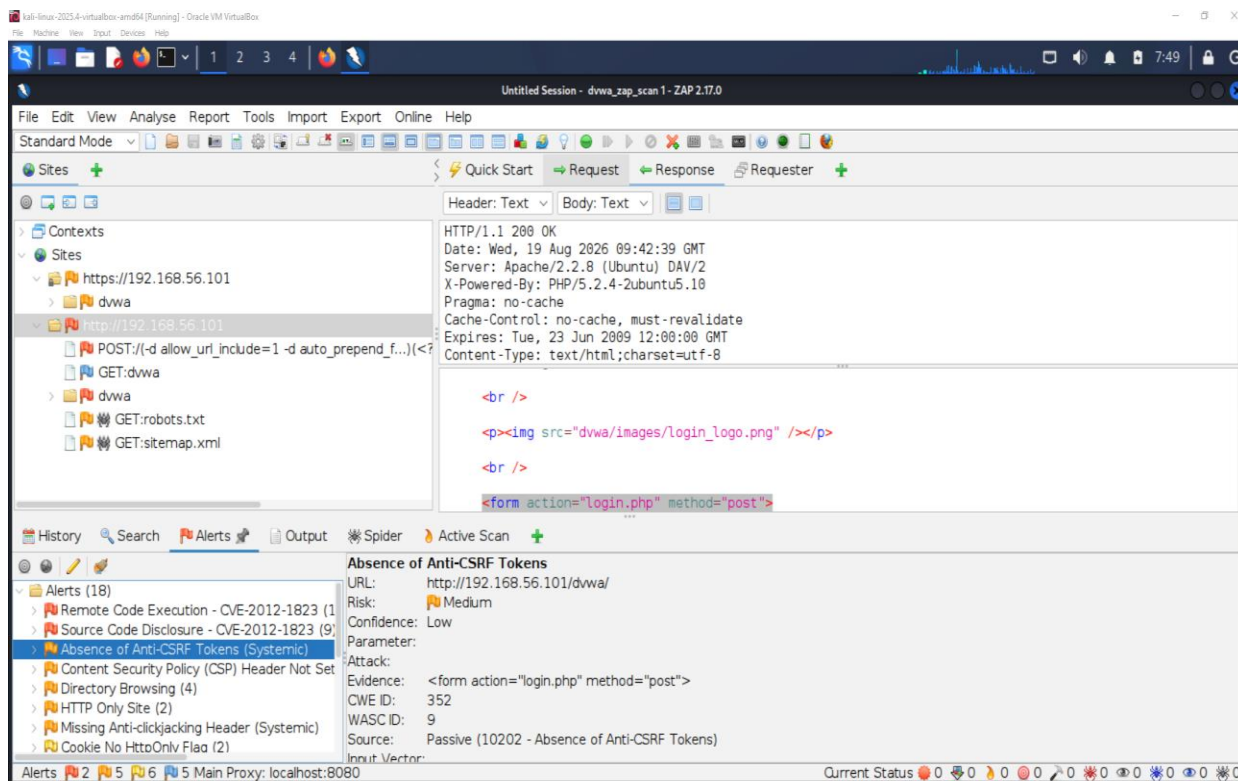


Figure 4: OWASP ZAP Alerts tab following the authenticated Active Scan of DVWA, showing the full alert tree (18 alerts) and detail view for "Absence of Anti-CSRF Tokens."

## 12.3 Severity Classification

SEV-1 (Critical) — the confirmed CVE-2012-1823 remote code execution is sufficient on its own to justify this classification: it is a working, unauthenticated exploit against 11 endpoints, not a theoretical weakness. Under the Incident Response Plan, this finding would trigger the same CBN 24-hour notification clock discussed in Section 8, and — because the exploited endpoint is the application layer customers actually interact with — would also carry direct NDPC exposure if any personal data were reachable through it.

## 12.4 Response Actions (Simulated, per Playbook A)

### Contain

1. Take the affected application offline or place it behind a maintenance page rather than leaving a confirmed RCE reachable.
2. Force-expire all active sessions and require re-authentication once the application is restored.
3. Preserve evidence: ZAP's full alert export, the exploited request/response pairs, and server logs covering the scan window.

### Eradicate

1. Patch the PHP-CGI configuration to remove the CVE-2012-1823 argument-injection path.
2. Deploy anti-CSRF tokens, security headers, and secure cookie flags across the application (see Section 12.5).

3. Move the password-change flow from GET to POST and audit for any other sensitive data traveling via URL.

### Recover

1. Re-run the authenticated ZAP scan to confirm the High-risk findings are closed before returning the application to service.
2. Rotate any credentials or session tokens that were active during the exposure window.

## 12.5 Hardening Recommendations (Application Layer)

| Recommendation                                                                          | Priority | Owner | Status | Target Date |
|-----------------------------------------------------------------------------------------|----------|-------|--------|-------------|
| Patch/upgrade PHP away from the vulnerable CGI-handler configuration (CVE-2012-1823)    | Critical | Eng   | Open   | Immediate   |
| Implement anti-CSRF tokens on all state-changing forms (login, password change, upload) | High     | Eng   | Open   | 1 week      |
| Enforce HTTPS/TLS across the entire application; redirect all HTTP traffic              | High     | Eng   | Open   | 1 week      |
| Set security headers: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options  | Medium   | Eng   | Open   | 2 weeks     |
| Set HttpOnly and SameSite=Strict/Lax on all session cookies                             | Medium   | Eng   | Open   | 2 weeks     |
| Disable directory listing on the web server                                             | Medium   | Eng   | Open   | 1 week      |
| Change the password-change form from GET to POST; never place sensitive data in a URL   | Medium   | Eng   | Open   | 2 weeks     |

## 12.6 Lessons Learned — Web Application Layer

- A version-level vulnerability (CVE-2012-1823) was independently discoverable and exploitable through the web layer, showing that network-layer hardening (Section 9) and application-layer hardening are both necessary — one does not substitute for the other.

- The systemic findings (missing CSRF tokens, missing security headers) matter less individually than in combination: absent CSRF protection is far more dangerous on a site that also has no CSP, since CSP is one of the few mitigations that limits what a successful CSRF or XSS attack can actually do.
- The automated Quick Start scan reached only the DVWA login page and returned negligible findings; nearly all 18 alerts, including the confirmed RCE, only surfaced once traffic was proxied through ZAP during a manual, authenticated walkthrough of the application. This was the clearest lesson of the exercise: scan configuration matters as much as the scan itself, and an unauthenticated scan against a login-gated application will significantly understate real risk..

### 13. Appendix B — Web Application Layer Evidence Log

- i. A version-level vulnerability (CVE-2012-1823) was independently discoverable and exploitable through the web layer, showing that network-layer hardening (Section 9) and application-layer hardening are both necessary — one does not substitute for the other.
- ii. The systemic findings (missing CSRF tokens, missing security headers) matter less individually than in combination: absent CSRF protection is far more dangerous on a site that also has no CSP, since CSP is one of the few mitigations that limits what a successful CSRF or XSS attack can actually do.
- iii. Running the attacker and victim VMs on a host-only network prevented accidental leakage into production, but also meant external threat-intel lookups had to be done manually on the host, highlighting the trade-off between safety and realism in lab design
- iv. Taking clean VM snapshots before each attack phase allowed rapid rollback when a containment step bricked the victim, reinforcing that snapshot policies should be part of any IR lab playbook

A full ZAP scanning report was exported and retained as a raw evidence file, confirming every alert in Section 12.2 with its complete request/response/attack detail, CWE/WASC references, and remediation guidance:



ZAP Full Report.pdf

*DVWA security level was set to "Low" for this scan, a deliberate scope decision documented in Section 2.4 — this setting maximizes the number of demonstrable vulnerabilities and should not be mistaken for the application's default configuration.*